



SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

Lima, 11 de enero de 2024

OFICIO N° 01690-2024-SBS

Señoras

YVETTE STEPHANY SANGUINETI CAMPOS

Directora de la Autoridad Nacional de Protección al Consumidor

EVELING ROA QUISPE

Secretaria Técnica de la Comisión de Protección al Consumidor N° 1

CECILIA VIOLETA SÁNCHEZ FONSECA

Secretaria Técnica (e) – Sala Especializada en Protección al Consumidor

Instituto Nacional de Defensa de la Competencia y de la Protección de la Propiedad Intelectual - INDECOPI

Referencia: Oficio N° 000592-2023-DPC/INDECOPI, Oficio N° 067-2022-CC1/INDECOPI y Oficio N° 051-2022-SPC/INDECOPI

Me dirijo a ustedes, con relación a las comunicaciones de la referencia, por medio de las cuales se consulta sobre la interpretación de las disposiciones del Reglamento para la Gestión de la Seguridad de la Información y la Ciberseguridad (Resolución SBS N° 504-2021), en adelante el Reglamento.

¿Se tiene algún pronunciamiento de la SBS que brinde mayores alcances respecto de la definición de los canales digitales, su interpretación y/o los mecanismos o medios que pueden estar comprendidos dentro de esta definición? ¿Cuáles son las características esenciales que identifican a los canales digitales? ¿Qué canales digitales se encuentran comprendidos en los términos de la Resolución SBS N° 504-2021?

¿Los cajeros automáticos y *point of sale* (POS) se encuentran comprendidos dentro de la definición de canal digital, establecida en el literal d) del artículo 2° del Reglamento? ¿Qué otro canal digital puede considerarse comprendido dentro de la definición establecida en el literal d) del artículo 2° del Reglamento?

¿Qué se debe entender por canal digital y si dicho concepto únicamente comprende a los servicios que son habilitados por la propia entidad financiera o en su defecto también comprende, por ejemplo, a páginas web de terceros (comercios electrónicos) donde los tarjetahabientes pueden realizar operaciones de compra, POS, cajeros electrónicos, entre otros?

El Reglamento establece lineamientos de carácter general que las entidades financieras deben implementar según el contexto particular de su operación, y no tiene por finalidad establecer una lista limitativa de canales considerados digitales o de describir todas las formas posibles de implementación.





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

Canal digital

El literal d) del Artículo 2° del Reglamento, establece que un canal digital es cualquier medio empleado por las empresas supervisadas para proveer servicios, cuyo almacenamiento, procesamiento y transmisión se realiza mediante la representación de datos en bits.

En ese sentido, los canales como comercios electrónicos, POS, cajeros automáticos y similares, a través de los cuales las entidades financieras proveen sus servicios a los usuarios, son considerados canales digitales, en lo que concierne a dichos servicios, en la medida que cumplen con la definición mencionada anteriormente.

Asimismo, en el marco del Reglamento, las empresas del sistema financiero son responsables de autenticar la identidad del usuario cuando este instruya transacciones que lo requieran, como el pago de servicios, tanto en canales propios como de terceros, con la excepción de las operaciones consideradas como micropago, operaciones por montos poco significativos y con un límite máximo que no requieren autenticación reforzada del usuario, por cuyas pérdidas es responsable la entidad financiera, conforme al numeral 6 del artículo 23° del Reglamento de Tarjetas de Crédito y Débito.

Autenticación reforzada

La autenticación reforzada es un requerimiento general, asociado a las condiciones específicas para cada operación que puede generar perjuicio al usuario. No obstante, existe un régimen de exención aplicable para situaciones de bajo riesgo efectuadas bajo responsabilidad de la empresa.

El artículo 19° del Reglamento establece que la autenticación debe ser reforzada para aquellas acciones que puedan originar operaciones fraudulentas u otro abuso del servicio en perjuicio del cliente, como las operaciones que impliquen pagos o transferencia de fondos a terceros, registro de un beneficiario de confianza, modificación en los productos de seguro ahorro/inversión contratados, la contratación de un producto o servicio, y la modificación de límites y condiciones. Asimismo, el artículo 20° prevé la exención de autenticación reforzada para: i) pagos y transferencia hacia beneficiarios de confianza previamente registrados por el usuario, ii) pagos y transferencias hacia cuentas en las que el beneficiario y el cliente sean la misma persona, y iii) bajo condiciones establecidas y responsabilidad de la empresa, cuando identifique una operación de bajo riesgo, como resultado de un análisis de riesgo en línea por operación.

¿Se puede considerar el ingreso a la banca móvil o por internet (con el uso de usuarios, claves, registro biométrico, entre otros) como uno de los factores de autenticación? Y, en caso ello sea afirmativo ¿El ingreso a la banca móvil o por internet podría ser considerado como un factor de autenticación que permitiría la realización de varias operaciones o únicamente la primera operación?

Entendemos que la consulta se refiere a si la validación de un factor de autenticación efectuada para el ingreso al aplicativo, por ejemplo, la validación de una contraseña puede ser reutilizada para la autenticación que permita realizar posteriores operaciones mientras el usuario no salga de la aplicación.

Al respecto, el Reglamento no niega si la validación de un factor, al ingresar a la banca móvil o por internet, puede ser reutilizada para autenticar operaciones posteriores. No obstante, el párrafo 17.1 del artículo 17° del citado Reglamento establece que, previo a implementar los procesos de autenticación,





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

la empresa debe evaluar formalmente y tomar medidas respecto a la línea base de controles para prevenir las amenazas a que esté expuesto el proceso de autenticación.

En tal sentido, tal reutilización sería posible, siempre que la empresa haya asegurado contar con la citada línea base y que, las operaciones que vayan a ejecutarse se encuentren en el alcance del monitoreo de transacciones, a fin de permitir la adopción de medidas que reduzcan la posibilidad de operaciones fraudulentas, conforme lo requiere el párrafo 17.4 del artículo 17° del Reglamento.

¿Qué se debe entender por enrolamiento según lo dispuesto por el Reglamento y si ello se encuentra vinculado solo al ingreso al canal o en su defecto también esa definición se extiende para la validación de una operación?

El enrolamiento al que hace referencia el artículo 18° del Reglamento es el proceso de verificación de identidad de los usuarios que realizan las empresas supervisadas, que tiene como resultado la generación y asignación de credenciales a dichos usuarios antes de la ejecución de operaciones. Posteriormente, gracias a dichas credenciales, que incluyen, por ejemplo, factores de autenticación, nombres, dirección y datos de contacto, los usuarios pueden efectuar operaciones a través de los sistemas informáticos.

Por otra parte, es decisión de la entidad financiera, si como parte del enrolamiento también le ofrece al usuario validar una operación, o si requiere que la validación de operaciones sea posterior y completamente separada del enrolamiento.

¿De qué modo se vería cumplida la Autenticación Reforzada (doble autenticación) a la que se refiere el artículo 19° del Reglamento para aquellas operaciones de compra realizadas a través de, por ejemplo, sitios web de un comercio electrónico ajeno a una entidad financiera donde no se efectúa un enrolamiento previo al canal digital?

La autenticación reforzada en caso se realice una operación de pago en un comercio electrónico se efectúa mediante los factores de autenticación que la entidad financiera implemente y ponga a disposición de los usuarios. En una situación común, el primer factor podría consistir en los datos contenidos en la tarjeta, los cuales son registrados por el usuario en la página web o App del comercio electrónico; el segundo factor, podría ser omitido por la entidad, bajo su responsabilidad, conforme a las condiciones establecidas para la exención de autenticación reforzada en el artículo 20¹ del Reglamento; caso contrario, aplicaría el segundo factor.

Cabe señalar que, el Reglamento no es aplicable a la afiliación (creación de usuario y/o contraseña) que se efectúa en determinados comercios electrónicos antes de efectuar compras y/o acceder a servicios de este.

¿Se mantiene la interpretación efectuada en el Boletín respecto de canales digitales?

¹ Cabe precisar que el numeral 2, del artículo 20° del Reglamento prevé la exención de autenticación reforzada bajo responsabilidad de la empresa, cuando identifique una operación de bajo riesgo, como resultado de un análisis de riesgo en línea por operación, sujeto a que haya adoptado los estándares de la industria de pagos con tarjetas, EMV 3DS y EMV payment tokenisation





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

¿Qué finalidad tienen los boletines emitidos por vuestra Superintendencia, es decir, si estos documentos tienen un carácter normativo y complementar las normas emitidas por su entidad o son meramente informativos?

Los boletines que publica la Superintendencia no tienen naturaleza regulatoria, ya que tienen un propósito informativo dirigido a un público general y que aborda diferentes temas, que pueden incluir buenas prácticas y recomendaciones no necesariamente requeridas o reguladas.

Finalmente, con relación al pedido recibido a través de la Plataforma Virtual - PLAVIR, asociado al Oficio SBS N° 36482-2022, remitimos el Anexo N° 1 de dicho documento que contiene las *"Instrucciones sobre aplicación de la Resolución SBS N° 504-2022"*.

Atentamente,

CARLOS ENRIQUE MELGAR ROMARIONI
SECRETARIO GENERAL

MCM, EVL, PSC, JIK





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

Anexo 1. Instrucciones sobre aplicación de la Resolución SBS N° 504-2022

1. Art. 2, literal j; Art. 18 y Art. 19. El registro por primera vez o el cambio de los factores de posesión (ejemplo, dispositivo móvil) o conocimiento (ejemplo, contraseña), que solo posee el usuario o que solo conoce el usuario, constituyen acciones con posible perjuicio al usuario al efectuarse por canal digital, por lo que requiere previa verificación de dos factores válidos.
2. Art. 2, literal j y Art. 19. El uso de preguntas de reto como factor que conoce solo el usuario, para fines de autenticación reforzada, requiere que sea el usuario quien las establezca, además de que cuando se almacena o transfiere sea de forma cifrada.
3. Art. 2, literal j. El uso del teléfono móvil como factor que solo posee el usuario, cuya posesión es probada mediante el envío de OTP vía SMS a dicho teléfono móvil, no constituye un factor válido, por su vulnerabilidad a suplantación vía SIM Swapping y la ausencia de condiciones técnicas que aseguren la confidencialidad de la transmisión de los mensajes SMS⁵.
4. Art. 2, literal j. El uso del teléfono móvil con una aplicación móvil instalada, como factor que solo posee el usuario, cuya posesión es probada mediante el uso de una OTP recibida en dicha aplicación móvil, no constituye un factor válido, a menos que dicho uso esté condicionado a que la aplicación verifique que el dispositivo móvil corresponde a aquel afiliado por el usuario al momento del enrolamiento.
5. Art. 2, literal j. La firma manuscrita registrada en un voucher o a través de una pantalla táctil no constituye un factor de autenticación de inherencia⁶, salvo que medie una validación de dicho factor que sea resistente a amenazas de suplantación, con un alto ratio de éxito⁷, contra un registro oficial o previamente constituido por la empresa.
6. Art. 2, literal j. La biométrica cuya validación es efectuada por los teléfonos y otros dispositivos móviles no constituyen factor de autenticación de inherencia⁶, salvo que dicha validación sea resistente a amenazas de suplantación, con un alto ratio de éxito⁷, contra un registro oficial o previamente constituido por la empresa.
7. Art. 2, literal j. La posesión de una tarjeta de crédito o débito, así como la información contenida en ellas, como factor que solo posee el usuario, constituye un único factor de autenticación.

⁵ SMS, Short Message Service, servicio de mensajería de textos disponible a través de los servicios de telecomunicaciones.

⁶ Factor de inherencia, corresponde a algo que el usuario es

⁷ Tomando en cuenta las recomendaciones desarrolladas por NIST e ISO/IEC, National Institute of Standards and Technology, y International Organization for Standardization/International Electrotechnical Commission, respectivamente.

